
**Information technology - Security techniques -
Information security management systems -
Requirements**

- تكنولوجيا المعلومات - تقنيات الأمن
- أنظمة إدارة أمن المعلومات
- المتطلبات

ترجمة مدقق الجودة المعتمد

ابراهيم حسين خنياب

قسم الجودة وتقييم الاداء المؤسسي

اللجنة الكهروتقنية الدولية

الرقم المرجعي (E) ISO / IEC 27001: 2013

ISO / IEC 2013

المحتويات

٠	مقدمة.
١	المجال
٢	المراجع المعيارية.
٣	المصطلحات والتعريفات.
٤	سياق المنظمة.
٤,١	فهم المنظمة وسياقها
٤,٢	فهم احتياجات وتوقعات الاطراف المهتمة
٤,٣	تحديد نطاق / مجال نظام إدارة أمن المعلومات
٤,٤	معلومات نظام إدارة أمن المعلومات
٥	القيادة
٥,١	القيادة والالتزام.
٥,٢	السياسة
٥,٣	الأدوار والمسؤوليات والصلاحيات التنظيمية
٦	التخطيط
٦,١	إجراءا تلمواجهة المخاطر والفرص
٦,٢	أهداف أمن المعلومات والتخطيط لتحقيقها
٧	الدعم
٧,١	الموارد
٧,٢	الكفاءة
٧,٣	الوعي
٧,٤	التواصل
٧,٥	المعلومات الموثقة
٨	العملية
٨,١	التخطيط والرقابة التشغيلية
٨,٢	تقييم مخاطر أمن المعلومات
٨,٣	معالجة مخاطر أمن المعلومات.
٩	تقييم الأداء
٩,١	المراقبة والقياس والتحليل والتقويم
٩,٢	التدقيق الداخلي
٩,٣	مراجعة الإدارة
١٠	التحسين
١٠,١	عدم المطابقة والإجراءات التصحيحية
١٠,٢	التحسين المستمر.
	الملحق A (المعياري) أهداف الرقابة المرجعية والضوابط.
	المراجع

مقدمة

تشكل ISO (المنظمة الدولية للتوحيد القياسي) و IEC (اللجنة الكهروتقنية الدولية) النظام المتخصص للتوحيد القياسي في جميع أنحاء العالم. تشارك الهيئات الوطنية الأعضاء في ISO أو IEC في تطوير المعايير الدولية من خلال اللجان الفنية التي أنشأتها المنظمة المعنية للتعامل مع مجالات معينة من النشاط الفني. تتعاون اللجان الفنية ISO و IEC في المجالات ذات الاهتمام المشترك. وتشارك في العمل منظمات دولية أخرى، حكومية وغير حكومية، بالتنسيق مع ISO و IEC. في مجال تكنولوجيا المعلومات، أنشأت ISO و IEC لجنة فنية مشتركة، ISO / IEC JTC 1.

تتم صياغة المعايير الدولية وفقاً للقواعد الواردة في توجيهات ISO / IEC، الجزء ٢. المهمة الرئيسية للجنة الفنية المشتركة هي إعداد المواصفات القياسية الدولية. توزع مسودة المواصفات القياسية الدولية التي أقرتها اللجنة الفنية المشتركة على الهيئات الوطنية للتصويت عليها. يتطلب النشر كمعيار دولي موافقة ٧٥٪ على الأقل من الهيئات الوطنية التي تدلي بصوتها.

يتم لفت الانتباه إلى احتمال أن تكون بعض عناصر هذه الوثيقة موضوع حقوق براءات الاختراع. لا تتحمل ISO و IEC مسؤولية تحديد أي من حقوق براءات الاختراع هذه أو جمعها.

تم إعداد ISO / IEC 27001 من قبل اللجنة الفنية المشتركة ISO / IEC JTC 1، تكنولوجيا المعلومات، اللجنة الفرعية SC 27، تقنيات أمن تكنولوجيا المعلومات. هذا الإصدار الثاني يلغي ويحل محل الإصدار الأول (ISO / IEC 27001: 2005)، الذي كان منقحاً من الناحية الفنية.

٠ مقدمة

١,٠ عام

تم إعداد هذه المواصفة القياسية الدولية لتوفير متطلبات إنشاء وتنفيذ وصيانة وتحسين نظام إدارة أمن المعلومات باستمرار. يعد اعتماد نظام إدارة أمن المعلومات قرارًا استراتيجيًا للمؤسسة .

يتأثر إنشاء وتنفيذ نظام إدارة أمن المعلومات في المنظمة باحتياجات المنظمة وأهدافها ومتطلبات الأمن والعمليات التنظيمية المستخدمة وحجم وهيكل المنظمة .

من المتوقع أن تتغير كل هذه العوامل المؤثرة بمرور الوقت .

يحافظ نظام إدارة أمن المعلومات على السرية والنزاهة وتوافر المعلومات من خلال تطبيق عملية إدارة المخاطر ويعطي الثقة للأطراف المهمة بأن المخاطر تدار بشكل مناسب.

من المهم أن يكون نظام إدارة أمن المعلومات جزءًا من عمليات المنظمة وهيكل الإدارة العام ومتكامل معها وأن يتم أخذ أمن المعلومات في الاعتبار عند تصميم العمليات وأنظمة المعلومات والضوابط .

من المتوقع أن يتم تطبيق نظام إدارة أمن المعلومات وفقًا لاحتياجات المنظمة .

يمكن استخدام هذه المواصفة القياسية الدولية من قبل الأطراف الداخلية والخارجية لتقييم قدرة المنظمة على تلبية متطلبات أمن المعلومات الخاصة بالمنظمة .

الترتيب الذي يتم تقديم المتطلبات به في هذه المواصفة القياسية الدولية لا يعكس أهميتها أو يشير ضمناً إلى الترتيب الذي سيتم تنفيذها به.

يتم تعداد عناصر القائمة لأغراض مرجعية فقط .

يصف ISO / IEC 27000 نظرة عامة ومفردات أنظمة إدارة أمن المعلومات ، الرجوع إلى عائلة معايير نظام إدارة أمن المعلومات والتي تشمل [2] ISO / IEC 27003 و [3] ISO / IEC 27004 و [4] ISO / IEC 27005 ، مع المصطلحات والتعريفات ذات الصلة .

٢,٠ التوافق مع معايير نظام الإدارة الأخرى

تطبق هذه المواصفة القياسية الدولية الهيكل عالي المستوى ، وعناوين البنود الفرعية المتطابقة ، والنص المتطابق ، والمصطلحات العامة ، والتعريفات الأساسية المحددة في الملحق SL لتوجيهات ISO / IEC ، الجزء ١ ، ملحق ISO الموحد ، وبالتالي تحافظ على التوافق مع

أنظمة الإدارة الأخرى التي اعتمدت الملحق SL .

سيكون هذا النهج المشترك المحدد في الملحق SL مفيداً لتلك المؤسسات التي تختار تشغيل نظام إدارة واحد يلبي متطلبات معيارين أو أكثر من معايير نظم الإدارة .

تكنولوجيا المعلومات - تقنيات الأمن - أنظمة إدارة أمن المعلومات - المتطلبات

١ المجال Scope

تحدد هذه المواصفة القياسية الدولية متطلبات إنشاء وتنفيذ وصيانة وتحسين نظام إدارة أمن المعلومات باستمرار في سياق المنظمة .
تتضمن هذه المواصفة القياسية الدولية أيضًا متطلبات التقييم والعلاج لمخاطر أمن المعلومات المصممة لاحتياجات المنظمة .
المتطلبات المنصوص عليها في هذه المواصفة القياسية الدولية عامة وتهدف إلى أن تكون قابلة للتطبيق على جميع المنظمات ، بغض النظر عن النوع أو الحجم أو الطبيعة .
يُعد استبعاد أي من المتطلبات المحددة في البنود من ٤ إلى ١٠ أمرًا غير مقبول عندما تدعي المنظمة التوافق مع هذه المواصفة القياسية الدولية .

٢ المراجع المعيارية Normative references

تمت الإشارة إلى الوثائق التالية ، كليًا أو جزئيًا ، بشكل معياري في هذه الوثيقة ولاغنى عنها لتطبيقها . للحصول على مراجع مؤرخة ، فقط تطبق الطبعة المذكورة .
بالنسبة للمراجع غير المؤرخة ، تطبق أحدث طبعة من الوثيقة المرجعية (بمافي ذلك أي تعديلات) ،
ISO / IEC 27000 ، تقنيات أمن تكنولوجيا المعلومات ، نظم إدارة أمن المعلومات - نظرة عامة ومفردات

٣ المصطلحات والتعاريف

لأغراض هذا المستند ، تنطبق المصطلحات والتعريفات الواردة في ISO / IEC 27000 .

٤ سياق المنظمة

٤,١ فهم المنظمة وسياقها

يجب على المنظمة تحديد القضايا الخارجية والداخلية ذات الصلة بغرضها والتي تؤثر على قدرتها على تحقيق النتيجة (النتائج) المقصودة لنظام إدارة أمن المعلومات .

ملاحظة: يشير تحديد هذه القضايا إلى إنشاء السياق الخارجي والداخلي للمؤسسة الوارد في الفقرة ٥,٣ من ISO 31000: 2009 [5].

٤,٢ فهم احتياجات وتوقعات الأطراف المعنية

تحدد المنظمة مايلي :

أ) الأطراف المهمة ذات الصلة بنظام إدارة أمن المعلومات .

ب) متطلبات هذه الأطراف ذات الصلة بأمن المعلومات .

ملاحظة: قد تتضمن متطلبات الأطراف المهمة متطلبات قانونية وتنظيمية والالتزامات التعاقدية

٤,٣ تحديد مجال نظام إدارة أمن المعلومات

يجب على المنظمة تحديد حدود وتطبيق نظام إدارة أمن المعلومات لتحديد نطاقه .

عند تحديد هذا النطاق ، يجب على المنظمة مراعاة مايلي :

- أ) القضايا الخارجية والداخلية المشار إليها في ٤,١ .
 - ب) المتطلبات المشار إليها في ٤,٢ . و
 - ج) الواجهات والتبعيات بين الأنشطة التي تقوم بها المنظمة وتلك التي تقوم بها المنظمات الأخرى .
- يجب أن يكون النطاق متاحًا كمعلومة موثقة .

٤,٤ نظام إدارة أمن المعلومات

يجب على المنظمة إنشاء نظام إدارة أمن المعلومات وتنفيذه وصيانته وتحسينه باستمرار ، وفقًا لمتطلبات هذه المواصفة القياسية الدولية .

٥ القيادة

٥,١ القيادة والالتزام

يجب أن تظهر الإدارة العليا القيادة والالتزام فيما يتعلق بنظام إدارة أمن المعلومات من خلال :

- أ) ضمان وضع سياسة أمن المعلومات وأهداف أمن المعلومات ومتوافقة مع التوجه الاستراتيجي للمنظمة .
- ب) ضمان تكامل متطلبات نظام إدارة أمن المعلومات في عمليات المنظمة .
- ج) التأكد من توفر الموارد اللازمة لنظام إدارة أمن المعلومات :
- د) إيصال أهمية الإدارة الفعالة لأمن المعلومات والامتثال لمتطلبات نظام إدارة أمن المعلومات .
- هـ) ضمان تحقيق نظام إدارة أمن المعلومات النتيجة (النتائج) المقصودة .
- و) توجيه ودعم الأشخاص للمساهمة في فعالية نظام أمن المعلومات .
- ز) تعزيز التحسين المستمر .
- ح) دعم الأدوار الإدارية الأخرى ذات الصلة لإثبات قيادتها كما تنطبق عليها مجالات المسؤولية .

٥,٢ السياسة

يجب أن تضع الإدارة العليا سياسة أمن المعلومات التي تكون :

- أ) مناسبة لغرض المنظمة .
 - ب) تتضمن أهداف أمن المعلومات (انظر ٦,٢) أو توفر إطار عمل لتحديد أهداف أمن المعلومات .
 - ج) تتضمن التزامًا بتلبية المتطلبات المعمول بها المتعلقة بأمن المعلومات .
 - د) تتضمن الالتزام بالتحسين المستمر لنظام إدارة أمن المعلومات .
- سياسة أمن المعلومات يجب أن :
- هـ) تكون متاحة كمعلومة موثقة .

(و) يتم توصيلها داخل المنظمة .

(ز) تكون متاحة للأطراف المعنية ، حسب الاقتضاء .

٥,٣ الأدوار والمسؤوليات والصلاحيات التنظيمية

يجب أن تضمن الإدارة العليا أن المسؤوليات والصلاحيات للأدوار ذات الصلة بأمن المعلومات قد تم تعيينها والإبلاغ عنها .

يجب على الإدارة العليا إسناد المسؤولية والسلطة لـ :

(أ) التأكد من أن نظام إدارة أمن المعلومات يتوافق مع متطلبات هذا المعيار الدولي .

(ب) رفع تقارير عن أداء نظام إدارة أمن المعلومات إلى الإدارة العليا .

ملاحظة: قد تقوم الإدارة العليا أيضًا بتعيين المسؤوليات والصلاحيات للإبلاغ عن أداء نظام إدارة أمن المعلومات داخل المنظمة .

٦ التخطيط

٦,١ إجراءات لمواجهة المخاطر و الفرص

٦,١,١ عام

عند التخطيط لنظام إدارة أمن المعلومات ، يجب على المنظمة النظر في القضايا المشار إليها في ٤,١ والمتطلبات المشار إليها

في ٤,٢ وتحديد المخاطر والفرص التي يجب معالجتها لـ :

(أ) التأكد من أن نظام إدارة أمن المعلومات يمكن أن يحقق النتيجة (النتائج) المقصودة .

(ب) منع أو تقليل الآثار غير المرغوب فيها .

(ج) تحقيق التحسين المستمر.

يجب على المنظمة التخطيط :

(د) إجراءات للتصدي لهذه المخاطر و الفرص .

(هـ) كيف

(١) دمج وتنفيذ الإجراءات في عمليات نظام إدارة أمن المعلومات .

(٢) تقييم فعالية هذه الإجراءات .

٦,١,٢ تقييم مخاطر أمن المعلومات

يجب على المنظمة تحديد وتطبيق عملية تقييم مخاطر أمن المعلومات التي :

(أ) تضع و تحافظ على معايير مخاطر أمن المعلومات التي تشمل :

(١) معايير قبول المخاطر .

(٢) معايير إجراء تقييمات مخاطر أمن المعلومات .

(ب) تضمن أن التقييمات المتكررة لمخاطر أمن المعلومات تؤدي إلى نتائج متسقة وصحيحة وقابلة للمقارنة .

ج) تحدد مخاطر أمن المعلومات :

١) تطبيق عملية تقييم مخاطر أمن المعلومات لتحديد المخاطر المرتبطة بفقدان السرية والسلامة وتوافر المعلومات ضمن نطاق نظام إدارة أمن المعلومات .

٢) تحديد أصحاب المخاطر .

د) تحليل مخاطر أمن المعلومات :

١) تقييم العواقب المحتملة التي قد تنتج إذا تحققت المخاطر المحددة في ٦,١,٢ ج) ١) .

٢) تقييم الاحتمالية الواقعية لحدوث المخاطر المحددة في ٦,١,٢ ج) ١) .

٣) تحديد مستويات المخاطر .

هـ) بتقييم مخاطر أمن المعلومات:

١) مقارنة نتائج تحليل المخاطر بمعايير المخاطر المحددة في ٦,١,٢ أ) .

٢) إعطاء الأولوية في المعالجة للمخاطر التي تم تحليلها .

يجب على المنظمة الاحتفاظ بالمعلومات الموثقة حول عملية التقييم لمخاطر أمن المعلومات .

٦,١,٣ معالجة مخاطر أمن المعلومات

يجب على المنظمة تحديد وتطبيق عملية معالجة مخاطر أمن المعلومات من أجل :

أ) تحديد خيارات معالجة مخاطر أمن المعلومات المناسبة ، مع مراعاة نتائج تقييم المخاطر .

ب) تحديد جميع الضوابط اللازمة لتنفيذ خيار (خيارات) معالجة مخاطر أمن المعلومات المختارة .

ملاحظة: يمكن للمؤسسات تصميم عناصر التحكم كما هو مطلوب ، أو التعرف عليها من أي مصدر .

ج) مقارنة الضوابط المحددة في ٦,١,٣ ب) أعلاه مع تلك الموجودة في الملحق A أو التحقق من أنه لم يتم حذف الضوابط اللازمة .

ملاحظة ١ يحتوي الملحق A على قائمة شاملة بأهداف التحكم و الضوابط . مستخدمو هذه المواصفة الدولية

يوجهون إلى الملحق A لضمان عدم التغاضي عن الضوابط الضرورية .

ملاحظة ٢ - أهداف التحكم مدرجة ضمنياً في الضوابط المختارة . أهداف التحكم والضوابط المدرجة في الملحق A ليست

شاملة وقد تكون هناك حاجة إلى أهداف وضوابط رقابة إضافية .

د) إصدار بيان قابلية التطبيق يحتوي على الضوابط الضرورية (انظر ٦,١,٣ ب) و ج)) ومبررات الإدراج ، سواء تم تنفيذها أم

لا، ومبررات استثناءات الضوابط من الملحق A .

هـ) صياغة خطة معالجة مخاطر أمن المعلومات .

و) الحصول على موافقة أصحاب المخاطر على خطة معالجة مخاطر أمن المعلومات وقبول مخاطر أمن المعلومات المتبقية .

يجب على المنظمة الاحتفاظ بالمعلومات الموثقة حول معالجة مخاطر أمن المعلومات

ملاحظة : تتماشى عملية تقييم مخاطر أمن المعلومات ومعالجتها في هذه المواصفة القياسية الدولية مع المبادئ والإرشادات

العامة الواردة في ISO 31000) .

٦,٢ أهداف أمن المعلومات والتخطيط لتحقيقها

يجب على المنظمة تحديد أهداف أمن المعلومات في الوظائف والمستويات ذات الصلة .

أهداف أمن المعلومات يجب أن :

(أ) أن تكون متسقة مع سياسة أمن المعلومات .

(ب) قابلة للقياس (إذا كان ذلك ممكناً عملياً) .

(ج) مراعاة متطلبات أمن المعلومات المطبقة ونتائج تقييم المخاطر و معالجة المخاطر .

(د) يتم إبلاغها .

(هـ) يتم تحديثها حسب الاقتضاء .

يجب على المنظمة الاحتفاظ بالمعلومات الموثقة حول أهداف أمن المعلومات. عند التخطيط لكيفية تحقيق أهداف أمن

المعلومات الخاصة بها ، يجب على المنظمة تحديد :

(و) ماسيتم القيام به .

(ز) ماهي الموارد المطلوبة .

(ح) من سيكون المسؤول .

(ط) متى سيتم الانتهاء منه .

كيف سيتم تقييم النتائج .

٧ الدعم

٧,١ الموارد.

يجب على المنظمة تحديد وتوفير الموارد اللازمة لإنشاء وتنفيذ وصيانة والتحسين المستمر لنظام إدارة أمن المعلومات .

٧,٢ الكفاءة

يجب على المنظمة :

(أ) تحديد الكفاءة اللازمة للأشخاص الذين يقومون بعمل تحت سيطرتها يؤثر على أداء أمن المعلومات .

(ب) التأكد من أن هؤلاء الأشخاص مؤهلين على أساس التعليم أو التدريب أو الخبرة المناسبة .

(ج) عند الاقتضاء ، اتخاذ الإجراءات لاكتساب الكفاءة اللازمة وتقييم فعالية الإجراءات المتخذة .

(د) الاحتفاظ بالمعلومات الموثقة المناسبة كدليل على الكفاءة .

ملاحظة: قد تشمل الإجراءات القابلة للتطبيق ، على سبيل المثال : توفير التدريب للموظفين الحاليين أو توجيههم أو إعادة

تعيينهم . أو تعيين أو التعاقد مع أشخاص مختصين .

٧,٣ الوعي

يجب أن يكون الأشخاص الذين يعملون تحت سيطرة المنظمة على دراية بما يلي :

(أ) سياسة أمن المعلومات .

- ب) مساهمتهم في فعالية نظام إدارة أمن المعلومات ، بما في ذلك فوائد تحسين أداء أمن المعلومات .
- ج) الآثار المترتبة على عدم التوافق مع متطلبات نظام إدارة أمن المعلومات .

٧,٤ التواصل

تحدد المنظمة الحاجة إلى الاتصالات الداخلية و الخارجية ذات الصلة بنظام إدارة أمن المعلومات بما في ذلك :

- أ) ما يجب التواصل .
- ب) متى يتم التواصل .
- ج) مع من تتواصل .
- د) من يتواصل .
- هـ) العمليات التي يتم من خلالها إجراء الاتصال .

٧,٥ المعلومات الموثقة

٧,٥,١ عام

يجب أن يتضمن نظام إدارة أمن المعلومات بالمنظمة مايلي :

- أ) المعلومات الموثقة التي تتطلبها هذه المواصفة القياسية الدولية .
- ب) المعلومات الموثقة التي تحددها المنظمة على أنها ضرورية لفعالية نظام إدارة أمن المعلومات .
- ملاحظة: يمكن أن يختلف مدى المعلومات الموثقة لنظام إدارة أمن المعلومات من منظمة إلى أخرى بسبب :
- ١) حجم المنظمة ونوع أنشطتها وعملياتها او منتجاتها .

٢) مدى تعقيد العمليات وتفاعلاتها .

٣) كفاءة الأشخاص .

٧,٥,٢ الإنشاء والتحديث

عند إنشاء المعلومات الموثقة وتحديثها ، يجب أن تضمن المنظمة مايلي :

- أ) التعريف والوصف (مثل العنوان أو التاريخ أو المعد أو الرقم المرجعي) .
- ب) التنسيق (مثل اللغة وإصدار البرنامج والرسومات) والوسائط (على سبيل المثال الورقية و الإلكترونية) .
- ج) المراجعة والموافقة على الملاءمة والكفاية .

٧,٥,٣ مراقبة المعلومات الموثقة

يجب التحكم في المعلومات الموثقة التي يتطلبها نظام إدارة أمن المعلومات وهذه المواصفة القياسية الدولية لضمان :

- أ) أنها متاحة ومناسبة للاستخدام ، أين ومتى تكون هناك حاجة إليها .
- ب) تتمتع بالحماية الكافية (على سبيل المثال من فقدان السرية أو الاستخدام غير السليم أو فقدان النزاهة) .

للتحكم في المعلومات الموثقة ، يجب على المنظمة معالجة الأنشطة التالية حسب الاقتضاء :

(ج) التوزيع والوصول والاسترجاع والاستخدام .

(د) التخزين والحفظ ، بما في ذلك الحفاظ على الوضوح .

(هـ) التحكم في التغييرات (مثل التحكم في الإصدار) .

(و) الاحتفاظ والتصرف .

يجب تحديد المعلومات الموثقة ذات المصدر الخارجي ، والتي تحددها المنظمة على أنها ضرورية لتخطيط وتشغيل نظام إدارة أمن المعلومات ، حسب الاقتضاء ، ويتم التحكم فيها .

ملاحظة: الوصول يعني القرار بشأن الإذن لعرض المعلومات الموثقة فقط ، أو الإذن والصلاحيات لعرض وتغيير المعلومات الموثقة ، إلخ.

٨ العملية

٨,١ التخطيط التشغيلي والرقابة

يجب على المنظمة تخطيط وتنفيذ ومراقبة العمليات اللازمة لتلبية متطلبات أمن المعلومات ، ولتنفيذ الإجراءات المحددة في ٦,١ .

يجب على المنظمة أيضاً تنفيذ خطط لتحقيق أهداف أمن المعلومات المحددة في ٦,٢ .

يجب على المنظمة الاحتفاظ بالمعلومات الموثقة بالقدر اللازم لتثبت أن العمليات قد تم تنفيذها كما هو مخطط لها .

يجب على المنظمة التحكم في التغييرات المخطط لها ومراجعة عواقب التغييرات غير المقصودة ، واتخاذ الإجراءات للتخفيف من أي آثار سلبية ، حسب الضرورة .

يجب على المنظمة التأكد من أن عمليات الاستعانة بمصادر خارجية يتم تحديدها والتحكم فيها .

٨,٢ تقييم مخاطر أمن المعلومات

يجب على المنظمة إجراء تقييم مخاطر أمن المعلومات على فترات مخطط لها أو متى تم اقتراح أو حدوث تغييرات مهمة ، مع مراعاة المعايير المحددة في ٦,١,٢ أ) . يجب على المنظمة الاحتفاظ بمعلومات موثقة لنتائج تقييمات مخاطر أمن المعلومات .

٨,٣ معالجة مخاطر أمن المعلومات

يجب على المنظمة تنفيذ خطة معالجة مخاطر أمن المعلومات .

يجب على المنظمة الاحتفاظ بمعلومات موثقة لنتائج معالجة مخاطر أمن المعلومات .

٩ تقييم الأداء

٩,١ المراقبة والقياس والتحليل والتقييم

يجب على المنظمة تقييم أداء أمن المعلومات وفعالية نظام إدارة أمن المعلومات .

تحدد المنظمة مايلي :

(أ) مايجب مراقبته وقياسه ، بما في ذلك عمليات وضوابط أمن المعلومات .

- ب) طرق المراقبة والقياس والتحليل والتقييم ، حسب الاقتضاء ، لضمان نتائج صحيحة .
- ملاحظة : يجب أن تنتج الطرق المختارة نتائج قابلة للمقارنة وقابلة للتكرار حتى تعتبر صالحة .
- ج) متى يتم إجراء المراقبة والقياس .
- د) من يقوم بالمراقبة والقياس .
- هـ) متى يتم تحليل وتقييم نتائج المراقبة والقياس .
- و) من يقوم بتحليل وتقييم هذه النتائج .
- يجب أن تحتفظ المنظمة بالمعلومات الموثقة المناسبة كدليل على المراقبة ونتائج القياس .

٩,٢ التدقيق الداخلي

- يجب على المنظمة إجراء عمليات تدقيق داخلي على فترات مخططة لتوفير معلومات حول ما إذا كان نظام إدارة أمن المعلومات :
- أ) يتوافق مع :
- ١) متطلبات المنظمة الخاصة لنظام إدارة أمن المعلومات الخاص بها .
- ٢) متطلبات هذه المواصفة القياسية الدولية .
- ب) يتم تنفيذه بشكل فعال والمحافظة عليه .
- يجب على المنظمة :
- ج) تخطيط وإنشاء وتنفيذ وصيانة برنامج (برامج) التدقيق ، بما في ذلك التكرار والأساليب والمسؤوليات ومتطلبات التخطيط وإعداد التقارير . يجب أن يأخذ برنامج (برامج) التدقيق بعين الاعتبار مراعاة أهمية العمليات المعنية ونتائج عمليات التدقيق السابقة .
- د) تحديد معايير التدقيق والمجال لكل تدقيق .
- هـ) اختيار المدققين وإجراء عمليات التدقيق التي تضمن موضوعية وحيادية عملية التدقيق .
- و) التأكد من أن نتائج عمليات التدقيق يتم إبلاغها إلى الإدارة ذات الصلة .
- ز) الاحتفاظ بالمعلومات الموثقة كدليل على برنامج (برامج) التدقيق ونتائج التدقيق .
- ## ٩,٣ مراجعة الإدارة

- يتعين على الإدارة العليا مراجعة نظام إدارة أمن المعلومات بالمنظمة في الموعد المخطط له لضمان استمرار ملاءمتها وكفائتها وفعاليتها .
- يجب أن تشمل مراجعة الإدارة النظر في :
- أ) حالة الإجراءات من مراجعات الإدارة السابقة .
- ب) التغييرات في القضايا الخارجية و الداخلية ذات الصلة بنظام إدارة أمن المعلومات .
- ج) المعلومات الراجعة على أداء أمن المعلومات ، بما في ذلك الاتجاهات في :
- ١) عدم المطابقة والإجراءات التصحيحية .
- ٢) نتائج الرصد والقياس .
- ٣) نتائج التدقيق .

٤) تحقيق أهداف أمن المعلومات .

د) ردود الفعل او المعلومات الراجعة من الأطراف المهمة .

هـ) نتائج تقييم المخاطر وحالة خطة معالجة المخاطر .

و) فرص التحسين المستمر .

يجب أن تتضمن مخرجات مراجعة الإدارة القرارات المتعلقة بفرص التحسين المستمر وأي احتياجات للتغييرات في نظام إدارة أمن المعلومات .

يجب على المنظمة الاحتفاظ بالمعلومات الموثقة كدليل على نتائج مراجعات الإدارة .

١٠ التحسين

١٠,١ عدم المطابقة والإجراءات التصحيحية

عندما تحدث عدم المطابقة ، يجب على المنظمة :

أ) اتخاذ رد فعل على عدم المطابقة ، وحسب الاقتضاء :

١) اتخاذ الإجراءات للسيطرة عليها وتصحيحها .

٢) التعامل مع العواقب .

ب) تقييم الحاجة إلى اتخاذ إجراء لإزالة أسباب عدم المطابقة ، بحيث لا تحدث أو تحدث في مكان آخر ، من خلال :

١) مراجعة عدم المطابقة .

٢) تحديد أسباب عدم المطابقة .

٣) تحديد ما إذا كانت حالات عدم المطابقة مماثلة موجودة ، أو يمكن أن تحدث .

ج) تنفيذ أي إجراء مطلوب .

د) مراجعة فعالية أي إجراء تصحيحي تم اتخاذه .

هـ) إجراء تغييرات على نظام إدارة أمن المعلومات ، إذا لزم الأمر .

يجب أن تكون الإجراءات التصحيحية مناسبة لتأثيرات حالات عدم المطابقة التي تمت مواجهتها .

يجب على المنظمة الاحتفاظ بالمعلومات الموثقة كدليل على :

و) طبيعة حالات عدم المطابقة وأي إجراءات لاحقة يتم اتخاذها .

ز) نتائج أي إجراء تصحيحي .

١٠,٢ التحسين المستمر

يجب على المنظمة استمرار تحسين ملاءمة وكفاية وفعالية معلومات نظام إدارة أمن المعلومات .

الملحق A (معياري)

أهداف الضوابط المرجعية

يتم اشتقاق أهداف الضوابط والضوابط المدرجة في الجدول A.1 مباشرة من تلك المدرجة في ISO / IEC 27002: 2013 ومواءمتها مع البنود من ٥ إلى ١٨ ويجب استخدامها في سياق الفقرة ٦,١,٣ .

الجدول A.1- أهداف التحكم والضوابط

A.5 سياسات أمن المعلومات		
A.5.1 توجيهات الإدارة لأمن المعلومات		
الهدف : توفير التوجيه و الدعم لإدارة لأمن المعلومات وفقاً لمتطلبات العمل والقوانين واللوائح ذات الصلة .		
A.5.1.1	سياسات لأمن المعلومات	مراقبة يجب تحديد مجموعة من السياسات الخاصة بأمن المعلومات واعتمادها من قبل الإدارة ونشرها وإبلاغها للموظفين والأطراف الخارجية ذات الصلة .
A.5.1.2	مراجعة سياسات أمن المعلومات	مراقبة يجب مراجعة سياسات أمن المعلومات على فترات مخططة أو في حالة حدوث تغييرات كبيرة لضمان استمرار ملاءمتها وكفائيتها وفعاليتها . التنفيذ و
A.6 تنظيم أمن المعلومات		
A.6.1 التنظيم الداخلي		
الهدف: إنشاء إطار عمل إداري لبدء ومراقبة تشغيل أمن المعلومات داخل المنظمة .		
A.6.1.1	أدوار ومسؤوليات أمن المعلومات	مراقبة يجب تحديد جميع مسؤوليات أمن المعلومات وتخصيصها
A.6.1.2	الفصل بين الواجبات.	مراقبة يجب فصل الواجبات ومجالات المسؤولية المتضاربة لتقليل فرص التعديل غير المصرح به أو غير المقصود أو إساءة استخدام أصول المنظمة .
A.6.1.3	الاتصال مع السلطات	مراقبة يجب الحفاظ على الاتصالات المناسبة مع السلطات ذات الصلة .
A.6.1.4	تواصل مع مجموعات المصالح الخاصة	مراقبة يجب الحفاظ على الاتصالات المناسبة مع مجموعات المصالح الخاصة أو غيرها من منظمات الأمن الخاصة والجمعيات المهنية .
A.6.1.5	أمن المعلومات في إدارة المشاريع	مراقبة يجب معالجة أمن المعلومات في إدارة المشروع ، بغض النظر عن نوع المشروع .
A.6.2 الأجهزة المحمولة والعمل عن بعد		
الهدف: ضمان أمن العمل عن بعد واستخدام الأجهزة المحمولة .		

الجدول A.1 (تابع)

A.6.2.1	سياسة الجهاز المحمول	مراقبة يجب اعتماد سياسة وتدابير أمنية داعمة لإدارة المخاطر الناتجة عن استخدام الأجهزة المحمولة .
A.6.2.2	العمل عن بعد	مراقبة يجب تنفيذ سياسة وتدابير أمنية داعمة لحماية المعلومات التي يتم الوصول إليها أو معالجتها أو تخزينها في مواقع العمل عن بُعد
A.7 أمن الموارد البشرية		
A.7.1 قبل التوظيف		
الهدف : التأكد من أن الموظفين والمقاولين يفهمون مسؤولياتهم وأنهم مناسبون للأدوار التي يؤدونها .		
A.7.1.1	تحري	مراقبة يجب إجراء فحوصات التحقق من الخلفية لجميع المرشحين للتوظيف وفقًا للقوانين واللوائح والأخلاق ذات الصلة ويجب أن تتناسب مع متطلبات العمل وتصنيف المعلومات التي سيتم الوصول إليها والمخاطر المحددة .
A.7.1.2	شروط وظروف التوظيف	مراقبة يجب أن تنص الاتفاقيات التعاقدية مع الموظفين والمقاولين على مسؤولياتهم و مسؤوليات المنظمة في ما يتعلق بأمن المعلومات .
A.7.2 أثناء العمل		
الهدف : التأكد من أن الموظفين والمقاولين على دراية بمسؤولياتهم المتعلقة بأمن المعلومات والوفاء بها .		
A.7.2.1	مسؤوليات الإدارة	مراقبة تطلب الإدارة من جميع الموظفين والمتعاقدين تطبيق أمن المعلومات وفقًا للسياسات والإجراءات المعمول بها في المنظمة
A.7.2.2	التوعية بأمن المعلومات والتعليم و التدريب	مراقبة يجب أن يتلقى جميع موظفي المنظمة ، وحيثما كان ذلك مناسبًا ، المقاولون تثقيفًا توعويًا وتدريبًا مناسبًا وتحديثات منتظمة في السياسات و الإجراءات التنظيمية ، حسب الاقتضاء لمتطلبات وظيفتهم .
A.7.2.3	عملية تأديبية	مراقبة يجب أن تكون هناك عملية تأديبية رسمية ومتصلة لاتخاذ إجراء ضد الموظفين الذين ارتكبوا خرقًا لأمن المعلومات .
A.7.3 إنهاء وتغيير الوظيفة		
الهدف : حماية مصالح المنظمة كجزء من عملية تغيير أو إنهاء العمل .		
A.7.3.1	إنهاء أو تغيير مسؤوليات التوظيف	مراقبة يجب تحديد مسؤوليات وواجبات أمن المعلومات التي تظل سارية للموظف أو المقاول وتنفيذها بعد إنهاء أو تغيير الوظيفة .
A.8 إدارة الأصول		
A.8.1 المسؤولية عن الأصول		

الجدول A.1 (تابع)

الهدف: تحديد الأصول التنظيمية وتحديد مسؤوليات الحماية المناسبة .		
A.8.1.1	جرد الأصول	مراقبة يجب تحديد الأصول المرتبطة بمرافق معالجة المعلومات والمعلومات و إعداد جرد لهذه الأصول و المحافظة عليه .
A.8.1.2	ملكية الأصول	مراقبة يجب أن تكون الأصول المحفوظة في المخزون مملوكة .
A.8.1.3	الاستخدام المقبول للأصول	مراقبة يجب تحدي وتوثيق وتنفيذ قواعد الاستخدام المقبول للمعلومات والأصول المرتبطة بمرافق معالجة المعلومات و المعلومات .
A.8.1.4	عودة الأصول	مراقبة يجب على جميع الموظفين و المستخدمين الخارجيين إعادة جميع الأصول التنظيمية التي بحوزتهم عند إنهاء عملهم أو عقدهم أو اتفاقهم .
A.8.2 تصنيف المعلومات		
الهدف : التأكد من أن المعلومات تتلقى مستوى مناسباً من الحماية وفقاً لأهميتها بالنسبة للمنظمة .		
A.8.2.1	تصنيف المعلومات	مراقبة يجب تصنيف المعلومات من حيث المتطلبات القانونية والقيمة والأهمية والحساسية للكشف أو التعديل غير المصرح به .
A.8.2.2	وسم المعلومات	مراقبة يجب أن تكون مجموعة الإجراءات المناسبة لتوسيم المعلومات وضعت و نفذت وفقاً لمعلومات مخطط التصنيف المعتمد من قبل المنظمة
A.8.2.3	التعامل مع الأصول	مراقبة . يجب تطوير إجراءات التعامل مع الأصول وتنفيذها وفقاً لنظام تصنيف المعلومات التي اعتمدها المنظمة .
A.8.3 التعامل مع الوسائط		
الهدف: منع إفشاء المعلومات أو تعديلها أو إلزائها أو إتلافها غير المصرح به مخزنة على الوسائط .		
A.8.3.1	إدارة الوسائط القابلة للإزالة	مراقبة يتم تنفيذ إجراءات إدارة الوسائط القابلة للإزالة وفقاً لنظام التصنيف المعتمد من قبل المنظمة .
A.8.3.2	التخلص من الوسائط	مراقبة يجب التخلص من الوسائط بشكل آمن عند عدم الحاجة إليها ، باستخدام الإجراءات الرسمية .
A.8.3.3	عبر الوسائط المادية	مراقبة يجب حماية الوسائط التي تحتوي على معلومات من الوصول غير المصرح به أو سوء الاستخدام أو الفساد أثناء النقل .
A.9 صلاحية التحكم صلاحية الدخول		
A.9.1 متطلبات العمل للتحكم في الوصول		

الجدول A.1 (تابع)

الهدف : للحد من الوصول إلى مرافق معالجة المعلومات والمعلومات .		
A.9.1.1	سياسة التحكم في الوصول	مراقبة يجب وضع سياسة للتحكم في الوصول وتوثيقه او مراجعتها بناءً على متطلبات أمن الأعمال والمعلومات .
A.9.1.2	الوصول إلى الشبكات وخدمات الشبكة -	مراقبة يجب فقط تزويد المستخدمين بإمكانية الوصول إلى الشبكة وخدمات العمل الصافية التي تم التصريح لهم باستخدامها على وجه التحديد .
A.9.2 إدارة وصول المستخدم		
الهدف: ضمان وصول المستخدم المصرح به ومنع الوصول غير المصرح به إلى الأنظمة والخدمات .		
A.9.2.1	تسجيل المستخدم وإلغاء التسجيل	مراقبة يجب تنفيذ عملية تسجيل وإلغاء تسجيل رسمية للمستخدم لتمكين تخصيص حقوق الوصول.
A.9.2.2	توفير وصول المستخدم	مراقبة يجب تنفيذ عملية توفير وصول المستخدم الرسمية لتعيين أو إبطال حقوق الوصول لجميع أنواع المستخدمين لجميع الأنظمة والخدمات .
A.9.2.3	إدارة حقوق الوصول الممنوحة	مراقبة يجب تقييد تخصيص واستخدام حقوق الوصول المميزة والتحكم فيها .
A.9.2.4	إدارة المصادقة السرية لمعلومات المستخدمين	مراقبة يجب التحكم في تخصيص معلومات المصادقة السرية من خلال عملية إدارة رسمية .
A.9.2.5	مراجعة حقوق وصول المستخدم	مراقبة يجب على مالكي الأصول مراجعة حقوق وصول المستخدمين على فترات منتظمة
A.9.2.6	إزالة أو تعديل حقوق الوصول	مراقبة يجب إزالة حقوق الوصول لجميع الموظفين والمستخدمين الخارجيين إلى مرافق معالجة المعلومات والمعلومات عند إنهاء عملهم أو عقدهم أو اتفاقهم ، أو تعديلها عند التغيير .
A.9.3 مسؤوليات المستخدم		
الهدف : جعل المستخدمين مسؤولين عن حماية معلومات المصادقة الخاصة بهم .		
A.9.3.1	استخدام معلومات المصادقة السرية	مراقبة يجب على المستخدمين اتباع ممارسات المنظمة في استخدام معلومات المصادقة السرية .
A.9.4 التحكم في الوصول إلى النظام والتطبيق		
الهدف : منع الوصول غير المصرح به إلى الأنظمة والتطبيقات .		
A.9.4.1	تقييد الوصول إلى المعلومات	مراقبة يجب تقييد الوصول إلى وظائف نظام المعلومات والتطبيقات وفقاً لسياسة التحكم في الوصول .
A.9.4.2	إجراءات تسجيل الدخول الآمنة	مراقبة عند الاقتضاء بموجب سياسة التحكم في الوصول ، يجب التحكم في الوصول إلى الأنظمة والتطبيقات من خلال إجراء تسجيل دخول آمن .

الجدول A.1 (تابع)

A.9.4.3	نظام إدارة كلمات المرور	مراقبة يجب أن تكون أنظمة إدارة كلمات المرور تفاعلية ويجب أن تضمن جودة كلمات المرور .
A.9.4.4	استخدام برامج الاستخدام المتميزة	مراقبة استخدام البرامج المساعدة التي قد تكون قادرة على تجاوز النظام والتطبيق يجب أن تكون ضوابط مقيدة ومحكمة خاضعة للسيطرة .
A.9.4.5	التحكم في الوصول إلى كود مصدر البرنامج	مراقبة يجب تقييد الوصول إلى رمز مصدر البرنامج .
A.10 التشفير		
A.10.1 ضوابط التشفير		
الهدف: ضمان الاستخدام السليم والفعال للتشفير لحماية السرية ، صحة و / أو سلامة المعلومات		
A.10.1.1	سياسة استخدام ضوابط التشفير	مراقبة يجب وضع وتنفيذ سياسة بشأن استخدام ضوابط التشفير لحماية المعلومات .
A.10.1.2	إدارة المفاتيح	مراقبة يجب تطوير وتنفيذ سياسة بشأن استخدام مفاتيح التشفير وحمايتها وعمرها طوال دورة حياتها الكاملة .
A.11 الأمن المادي و البيئي		
A.11.1 المناطق الأمانة		
الهدف: منع الوصول المادي غير المصرح به والضرر والتدخل في معلومات المنظمة ومرافق معالجة المعلومات .		
A.11.1.1	محيط الأمن المادي .	مراقبة يجب تحديد المحيط الأمني واستخدامه لحماية المناطق التي تحتوي إما على معلومات حساسة أو مرافق معالجة المعلومات .
A.11.1.2	ضوابط الدخول المادي	مراقبة يجب حماية المناطق الأمانة بواسطة ضوابط دخول مناسبة لضمان السماح فقط للأفراد المصرح لهم بالدخول .
A.11.1.3	تأمين المكاتب والغرف والمرافق	مراقبة يجب تصميم وتطبيق الأمن المادي للمكاتب والغرف والمرافق .
A.11.1.4	الحماية من التهديدات الخارجية والبيئية	مراقبة يجب تصميم وتطبيق الحماية المادية ضد الكوارث الطبيعية أو الهجمات الخبيثة أو الحوادث .
A.11.1.5	العمل في مناطق أمانة	مراقبة يجب تصميم وتطبيق إجراءات العمل في المناطق الأمانة
A.11.1.6	مناطق التسليم و التحميل	مراقبة يجب التحكم في نقاط الوصول مثل مناطق التسليم والتحميل وغيرها من النقاط التي يمكن للأشخاص غير المصرح لهم الدخول منها إلى المبنى ، وإذا أمكن عزلها عن مرافق معالجة المعلومات لتجنب الوصول غير المصرح به .

الجدول A.1 (تابع)

A.11.2 المعدات		
الهدف: منع فقدان الأصول أو إتلافها أو سرقتها أو الإضرار بها وتعطيل عمليات المنظمة .		
A.11.2.1	تحديد مواقع المعدات وحمايتها	مراقبة يجب وضع المعدات وحمايتها لتقليل المخاطر الناجمة عن التهديدات والمخاطر البيئية ، وفرص الوصول غير المصرح به .
A.11.2.2	دعم خدمات	مراقبة يجب حماية المعدات من انقطاع التيار الكهربائي والانفصال الناتج عن الأعطال في المرافق الداعمة .
A.11.2.3	أمن الكابلات	مراقبة يجب حماية كابلات الطاقة والاتصالات التي تحمل البيانات أو خدمات المعلومات من الاعتراض أو التداخل أو التلف .
A.11.2.4	صيانة المعدات	مراقبة يجب صيانة المعدات بشكل صحيح لضمان استمرار توافرها وسلامتها .
A.11.2.5	إزالة الأصول	مراقبة لايجوز نقل المعدات أو المعلومات أو البرامج من الموقع دون إذن مسبق .
A.11.2.6	أمن المعدات والأصول خارج الموقع	مراقبة يجب تطبيق الأمن على الأصول خارج الموقع مع مراعاة المخاطر المختلفة للعمل خارج مباني المنظمة .
A.11.2.7	التخلص الآمن من المعدات أو إعادة استخدامها	مراقبة يجب التحقق من جميع أصناف المعدات التي تحتوي على وسائط التخزين تمت إزالتها أو الكتابة فوقها بشكل آمن قبل التخلص منها أو إعادة استخدامها
A.11.2.8	المعدات المستخدمة غير المراقبة	مراقبة يجب على المستخدمين التأكد من أن المعدات غير المراقبة مناسبة
A.11.2.9	سياسة مكتب واضح و شاشة واضحة	مراقبة يجب اعتماد سياسة مكتبية واضحة للأوراق ووسائط التخزين القابلة للإزالة وسياسة شاشة واضحة لمنشآت معالجة المعلومات .
A.12 أمن العمليات		
A.12.1 الإجراءات والمسؤوليات التشغيلية		
الهدف: ضمان العمليات الصحيحة والأمنة لمرافق معالجة المعلومات .		
A.12.1.1	إجراءات التشغيل الموثقة	مراقبة يجب توثيق إجراءات التشغيل وإتاحتها لجميع المستخدمين الذين يحتاجون إليها .
A.12.1.2	إدارة التغيير	مراقبة يجب التحكم في التغييرات التي تطرأ على المنظمة والعمليات التجارية ومرافق معالجة المعلومات والأنظمة التي تؤثر على أمن المعلومات .

الجدول A.1 (تابع)

A.12.1.3	إدارة القدرات	مراقبة يجب مراقبة استخدام الموارد وضبطها ووضع توقعات لمتطلبات السعة المستقبلية لضمان أداء النظام المطلوب .
A.12.1.4	فصل بيئة التطوير والاختبار والتشغيل	مراقبة يجب تصنيف بيئات التطوير والاختبار والتشغيل بشكل منفصل لتقليل مخاطر الوصول غير المصرح به أو التغييرات في بيئة التشغيل .
A.12.2 الحماية من البرامج الضارة		
الهدف: ضمان حماية مرافق معالجة المعلومات والمعلومات من البرامج الضارة .		
A.12.2.1	ضوابط ضد البرامج الضارة	مراقبة يجب تنفيذ ضوابط الكشف والوقاية والاسترداد للحماية من البرامج الضارة ، جنباً إلى جنب مع وعي المستخدم المناسب .
A.12.3 النسخ الاحتياطي		
الهدف: الحماية من فقدان البيانات .		
A.12.3.1	النسخ الاحتياطي للمعلومات	مراقبة يجب أخذ نسخ احتياطية من المعلومات والبرامج وصور النظامي واختبارها بانتظام وفقاً لسياسة النسخ الاحتياطي المتفق عليها .
A.12.4 التسجيل والرصد		
الهدف: تسجيل الأحداث وتوليد الأدلة .		
A.12.4.1	تسجيل الأحداث	مراقبة يجب إنتاج سجلات الأحداث التي تسجل أنشطة المستخدم والاستثناءات والأعطال وأحداث أمن المعلومات والاحتفاظ بها ومراجعتها بانتظام
A.12.4.2	حماية معلومات السجل	مراقبة يجب حماية مرافق التسجيل ومعلومات السجل من العبث والوصول غير المصرح به
A.12.4.3	سجلات المسؤول والمشغل	مراقبة يجب تسجيل أنشطة مسؤول النظام ومشغل النظام وحماية السجلات ومراجعتها بانتظام .
A.12.4.4	مزامنة الساعة	مراقبة يجب مزامنة ساعات جميع أنظمة معالجة المعلومات ذات الصلة داخل المنظمة أو مجال الأمان مع مصدر زمني مرجعي واحد .
A.12.5 التحكم في البرامج التشغيلية		
الهدف : لضمان سلامة أنظمة التشغيل .		
A.12.5.1	تركيب الأدوات البرمجية على أنظمة التشغيل	مراقبة يجب تنفيذ إجراءات للتحكم في تركيب البرمجيات على أنظمة التشغيل .
A.12.6 إدارة نقاط الضعف الفنية		
الهدف: منع استغلال نقاط الضعف التقنية .		

الجدول A.1 (تابع)

A.12.6.1	إدارة نقاط الضعف الفنية	مراقبة يجب الحصول على المعلومات حول نقاط الضعف الفنية لأنظمة المعلومات المستخدمة في الوقت المناسب ، وتقييم تعرض المنظمة لهذه الثغرات واتخاذ التدابير المناسبة لمواجهة المخاطر المرتبطة بها .
A.12.6.2	قيود على تثبيت البرمجيات	مراقبة يجب وضع وتنفيذ القواعد التي تحكم تثبيت البرامج من قبل المستخدمين .
A.12.7 اعتبارات تدقيق نظم المعلومات الهدف: تقليل تأثير أنشطة التدقيق على أنظمة التشغيل .		
A.12.7.1	ضوابط تدقيق نظم المعلومات	مراقبة يجب التخطيط بعناية لمتطلبات التدقيق والأنشطة التي تتضمن التحقق من أنظمة التشغيل والموافقة عليها لتقليل الاضطرابات في العمليات .
A.13 أمن الاتصالات		
A.13.1 إدارة أمن الشبكة الهدف: ضمان حماية المعلومات في الشبكات ومرافق معالجة المعلومات الداعمة لها .		
A.13.1.1	ضوابط الشبكة	مراقبة يجب إدارة الشبكات والتحكم فيها لحماية المعلومات في الأنظمة والتطبيقات .
A.13.1.2	أمن خدمات الشبكة	مراقبة تتطلب آليات الأمن ومستويات الخدمة والإدارة ملاحظات لجميع خدمات الشبكة و يجب تحديدها وإدراجها في اتفاقيات خدمات الشبكة ، سواء تم توفير هذه الخدمات داخلياً أو تم الاستعانة بمصادر خارجية .
A.13.1.3	الفصل في الأعمال الشبكية	مراقبة يجب فصل مجموعات خدمات المعلومات والمستخدمين وأنظمة المعلومات على الشبكات .
A.13.2 نقل المعلومات الهدف: الحفاظ على أمن المعلومات المنقولة داخل المنظمة ومع أي كيان خارجي .		
A.13.2.1	سياسات وإجراءات نقل المعلومات	مراقبة يجب وضع سياسات وإجراءات وضوابط النقل الرسمية لحماية نقل المعلومات من خلال استخدام جميع أنواع مرافق الاتصال .
A.13.2.2	اتفاقيات نقل المعلومات	مراقبة يجب أن تتناول الاتفاقيات النقل الأمن لمعلومات الأعمال بين المنظمة والأطراف الخارجية .
A.13.2.3	الرسائل الإلكترونية	مراقبة يجب أن تكون المعلومات الواردة في الرسائل الإلكترونية محمية بشكل مناسب .

الجدول A.1 (تابع)

مراقبة يجب تحديد متطلبات اتفاقيات السرية أو عدم الإفشاء التي تعكس احتياجات المنظمة لحماية المعلومات ، ومراجعتها وتوثيقها بانتظام .	A.13.2.4 اتفاقيات السرية أو عدم الإفشاء	
A.14 اقتناء النظام وتطويره وصيانته		
A.14.1 متطلبات الأمن لأنظمة المعلومات		
الهدف: التأكد من أن أمن المعلومات هوجزء لايتجزأ من أنظمة المعلومات عبردورة حياة كاملة . ويشمل ذلك أيضا متطلبات أنظمة المعلومات التي تقدم الخدمات عبر الشبكات العامة .		
مراقبة يجب تضمين المتطلبات المتعلقة بأمن المعلومات في متطلبات أنظمة المعلومات الجديدة أو التحسينات على أنظمة المعلومات الحالية .	A.14.1.1 تحليل متطلبات أمن المعلومات والمواصفات	
مراقبة يجب حماية المعلومات المتضمنة في خدمات التطبيقات التي تمر عبر الشبكات العامة من النشاط الاحتيالي و نزاع العقد والكشف والتعديل غير المصرح بهما .	A.14.1.2 تأمين خدمات التطبيقات على الشبكات العامة	
مراقبة يجب حماية المعلومات المتضمنة في معاملات خدمة التطبيق لمنع النقل غير الكامل ، أو التوجيه الخاطئ ، أو تغيير الرسائل غير المصرح به ، أو الكشف غير المصرح به ، أو تكرار الرسائل غير المصرح بها أو إعادة عرضها .	A.14.1.3 حماية معاملات خدمات التطبيق	
A.14.2 الأمن في عمليات التطوير والدعم		
الهدف: التأكد من أن أمن المعلومات قد تم تصميمه وتنفيذه خلال دورة حياة تطوير أنظمة المعلومات .		
مراقبة يجب وضع قواعد تطوير البرمجيات والأنظمة وتطبيقها على التطورات داخل المنظمة .	A.14.2.1 سياسة التنمية الأمانة	
مراقبة يجب أن يتم التحكم في التغييرات التي يتم إجراؤها على الأنظمة خلال دورة حياة التطوير من خلال استخدام إجراءات مراقبة التغيير الرسمية .	A.14.2.2 إجراءات التحكم في تغيير النظام	
مراقبة عند تغيير منصات التشغيل ، يجب مراجعة التطبيقات المهمة للأعمال واختبارها للتأكد من عدم وجود تأثير سلبي على العمليات التنظيمية أو الأمن .	A.14.2.3 المراجعة الفنية للتطبيقات بعد تغييرات منصة التشغيل	
مراقبة يجب عدم تشجيع التعديلات على حزم البرامج ، وتقتصر على التغييرات الضرورية ويجب أن تخضع جميع التغييرات لرقابة صارمة .	A.14.2.4 قيود على تغييرات حزم البرامج	
مراقبة يجب إنشاء مبادئ هندسة النظم الأمانة وتوثيقها وصيانتها وتطبيقها على أي جهود لتنفيذ نظام المعلومات .	A.14.2.5 تأمين مبادئ هندسة النظام	

الجدول A.1 (تابع)

A.14.2.6	بيئة تطوير آمنة	مراقبة يجب على المنظمات إنشاء بيئات تطوير آمنة وحمايتها بشكل مناسب لتطوير النظام وجهود التكامل التي تغطي دورة حياة تطوير النظام بأكملها .
A.14.2.7	الاستعانة بمصادر تطوير خارجية	مراقبة يجب أن تشرف المنظمة وتراقب نشاط تطوير النظام بمصادر خارجية .
A.14.2.8	اختبار أمان النظام	مراقبة يجب إجراء اختبار الأداء الأمني أثناء التطوير .
A.14.2.9	اختبارات قبول النظام	مراقبة يجب أن تؤسس برامج اختبار قبول التحكم والمعايير ذات الصلة لأنظمة المعلومات الجديدة والترقيات والإصدارات الجديدة .
A.14.3 بيانات الاختبار		
الهدف: ضمان حماية البيانات المستخدمة للاختبار .		
A.14.3.1	حماية بيانات الاختبار	مراقبة يجب اختيار بيانات الاختبار بعناية وحمايتها و التحكم فيها .
A.15 علاقات الموردين		
A.15.1 أمن المعلومات في العلاقات مع الموردين		
الهدف: ضمان حماية أصول المنظمة التي يمكن للموردين الوصول إليها .		
A.15.1.1	سياسة أمن المعلومات للعلاقات مع الموردين	مراقبة يجب الاتفاق مع المورد على متطلبات أمن المعلومات للتخفيف من المخاطر المرتبطة بوصول المورد إلى أصول المنظمة وتوثيقها .
A.15.1.2	معالجة الأمن في اتفاقيات الموردين	مراقبة يجب وضع جميع متطلبات أمن المعلومات ذات الصلة و الاتفاق عليها مع كل مورد يمكنه الوصول إلى مكونات البنية التحتية لتكنولوجيا المعلومات أو معالجتها أو تخزينها أو توصيلها أو توفيرها لمعلومات المؤسسة .
A.15.1.3	سلسلة توريد تكنولوجيا المعلومات والاتصالات	مراقبة يجب أن تتضمن الاتفاقيات مع الموردين متطلبات معالجة مخاطر أمن المعلومات المرتبطة بخدمات تكنولوجيا المعلومات والاتصالات وسلسلة توريد المنتجات .
A.15.2 إدارة تقديم خدمة الموردين		
الهدف: الحفاظ على مستوى متفق عليه لأمن المعلومات وتقديم الخدمات بما يتماشى مع اتفاقيات التوريد .		
A.15.2.1	مراقبة ومراجعة خدمات الموردين	مراقبة يجب على المنظمات مراقبة ومراجعة وتقديم خدمات الموردين بشكل منتظم .
A.15.2.2	إدارة التغييرات على خدمات الموردين	مراقبة يجب إدارة التغييرات التي تطرأ على تقديم الخدمات من قبل الموردين ، بما في ذلك الحفاظ على سياسات وإجراءات وضوابط أمن المعلومات الحالية وتحسينها ، مع مراعاة أهمية معلومات الأعمال والأنظمة والعمليات المعنية وإعادة تقييم المخاطر .

الجدول A.1 (تابع)

A.16 إدارة حوادث أمن المعلومات		
A.16.1 إدارة حوادث أمن المعلومات والتحسينات		
الهدف : ضمان اتباع نهج متسق وفعال لإدارة حوادث أمن المعلومات ، بما في ذلك التواصل بشأن الأحداث الأمنية ونقاط الضعف .		
A.16.1.1	المسؤوليات والإجراءات	مراقبة يجب وضع مسؤوليات وإجراءات الإدارة لضمان استجابة سريعة وفعالة ومنظمة لحوادث أمن المعلومات .
A.16.1.2	الإبلاغ عن أحداث أمن المعلومات .	مراقبة يجب الإبلاغ عن أحداث أمن المعلومات من خلال قنوات الإدارة المناسبة في أسرع وقت ممكن .
A.16.1.3	الإبلاغ عن نقاط ضعف أمن المعلومات	مراقبة سُيطلب من الموظفين والمقاولين الذين يستخدمون أنظمة وخدمات المعلومات الخاصة بالمنظمة ملاحظة أي نقاط ضعف في أمن المعلومات ملحوظة أو مشتبه بها في الأنظمة أو الخدمات والإبلاغ عنها .
A.16.1.4	تقييم واتخاذ قرار بشأن الأحداث الأمنية المعلوماتية	مراقبة يجب تقييم أحداث أمن المعلومات وتقرر ما إذا كان سيتم تصنيفها على أنها أمن المعلومات
A.16.1.5	الاستجابة للحوادث الأمنية المعلوماتية	مراقبة يتم الرد على حوادث أمن المعلومات وفق الإجراءات الموثقة .
A.16.1.6	التعلم من حوادث أمن المعلومات	مراقبة يجب استخدام المعرفة المكتسبة من تحليل حوادث أمن المعلومات وحلها لتقليل احتمالية أو تأثير الحوادث المستقبلية .
A.16.1.7	جمع الأدلة	مراقبة يجب على المنظمة تحديد وتطبيق إجراءات توثيق المعلومات وجمعها والحصول عليها والمحافظة عليها والتي يمكن أن تكون بمثابة دليل .
A.17 جوانب أمن المعلومات لإدارة استمرارية الأعمال		
A.17.1 استمرارية أمن المعلومات		
الهدف: يجب أن تكون استمرارية أمن المعلومات جزءا لا يتجزأ من أنظمة إدارة استمرارية الأعمال في المنظمة .		
A.17.1.1	تخطيط استمرارية أمن المعلومات	مراقبة يجب على المنظمة تحديد متطلباتها لأمن المعلومات واستمرارية إدارة أمن المعلومات في المواقف المعاكسة ، على سبيل المثال خلال أزمة أو كارثة .
A.17.1.2	تنفيذ استمرارية أمن المعلومات	مراقبة يجب على المنظمة إنشاء وتوثيق وتنفيذ العمليات والإجراءات والضوابط الرئيسية لضمان المستوى المطلوب من الاستمرارية لأمن المعلومات أثناء المواقف المعاكسة.

الجدول A.1 (تابع)

A.17.1.3	التحقق من واستعراض وتقييم استمرارية أمن المعلومات	مراقبة يجب على المنظمة التحقق من ضوابط استمرارية أمن المعلومات الموضوعية والمنفذة على فترات منتظمة للتأكد من أنها صالحة وفعالة أثناء المواقف المعاكسة .
A.17.2	التكرار	
	الهدف: ضمان توافر مرافق معالجة المعلومات	
A.17.2.1	توفر مرافق معالجة المعلومات	مراقبة يجب تنفيذ تسهيلات معالجة المعلومات مع إعادة تفصيل كافية لتلبية متطلبات التوافر .
A.18	الامتثال	
A.18.1	الامتثال للمتطلبات القانونية والتعاقدية	
	الهدف: تجنب انتهاكات الالتزامات القانونية أو التنظيمية أو التعاقدية المتعلقة بأمن المعلومات وأي متطلبات أمنية .	
A.18.1.1	تحديد التشريعات المعمول بها والمتطلبات التعاقدية	مراقبة يجب تحديد جميع التشريعات القانونية والتنظيمية والتعاقدية ذات الصلة والإقرارات ، ويجب تحديد نهج المنظمة للوفاء بهذه المتطلبات بشكل صريح وتوثيقه وتحديثه لكل نظام المعلومات والمنظمة .
A.18.1.2	حقوق الملكية الفكرية	مراقبة يجب تنفيذ الإجراءات المناسبة لضمان الامتثال للمتطلبات التشريعية والتنظيمية والتعاقدية المتعلقة بحقوق الملكية الفكرية واستخدام منتجات البرمجيات المسجلة الملكية .
A.18.1.3	حماية السجلات	مراقبة يجب حماية السجلات من الضياع والتلف والتزوير والوصول غير المصرح به والإفراج غير المصرح به ، وفقاً للمتطلبات التشريعية والتنظيمية والتعاقدية والتجارية .
A.18.1.4	الخصوصية وحماية المعلومات الشخصية	مراقبة يجب ضمان الخصوصية وحماية معلومات التعريف الشخصية على النحو المطلوب في التشريعات واللوائح ذات الصلة عند الاقتضاء .
A.18.1.5	تنظيم ضوابط رسوم التشفير	مراقبة يجب استخدام ضوابط التشفير وفقاً لجميع الاتفاقيات والتشريعات واللوائح ذات الصلة .
A.18.2	مراجعات أمن المعلومات	
	الهدف: التأكد من أن أمن المعلومات يتم تنفيذه وتشغيله وفقاً للسياسات والإجراءات التنظيمية .	
A.18.2.1	مراجعة مستقلة لأمن المعلومات	مراقبة يجب مراجعة نهج المنظمة لإدارة أمن المعلومات وتنفيذه (أي أهداف الرقابة والضوابط والسياسات والعمليات والإجراءات الخاصة بأمن المعلومات) بشكل مستقل على فترات مخططة أو عند حدوث تغييرات كبيرة .

الجدول A.1 (تابع)

مراقبة يجب على المديرين أن يراجعوا بانتظام امتثال معالجة المعلومات والإجراءات في منطقة مسؤوليتهم مع السياسات والمعايير الأمنية المناسبة وأي متطلبات أمنية أخرى .	الامتثال لسياسات ومعايير الأمن	A.18.2.2
مراقبة يجب مراجعة أنظمة المعلومات بانتظام للتأكد من امتثالها لسياسات أمن المعلومات الخاصة بالمنظمة .	مراجعة الامتثال الفني	A.18.2.3

المراجع

- [١] ISO / IEC 27002: 2013 ، تكنولوجيا المعلومات - تقنيات الأمن - مدونة قواعد الممارسة لضوابط أمن المعلومات
- [٢] ISO / IEC 27003 ، تكنولوجيا المعلومات - تقنيات الأمن - إدارة أمن معلومات - إرشادات تنفيذ النظام
- [٣] ISO / IEC 27004 .تكنولوجيا المعلومات - تقنيات الأمن - إدارة أمن المعلومات - القياس
- [٤] ISO / IEC 27005 ،تكنولوجيا المعلومات - تقنيات أمن المعلومات - إدارة مخاطر أمن المعلومات
- [٥] ISO 31000: 2009 ،إدارة المخاطر - المبادئ والإرشادات توجيهات
- [٦] ISO / IEC التوجيهات ، الجزء ١ ،ملحق ISO الموحد - الإجراءات الخاصة بـ ISO 2012

